# Combined US Operations of Banco Santander, S.A.

## Technology




# Authentication and Authorization Standard

# TABLE OF CONTENTS

1. INTRODUCTION ..... 3
1.1 PURPOSE OF THIS DOCUMENT ..... 3
1.2 SCOPE AND PERIMETER ..... 3
1.3 DOCUMENT OWNERSHIP, APPROVAL AND MAINTENANCE ..... 3
2. GOVERNANCE AND ACCOUNTABILITY ..... 4
2.1 STANDARD GOVERNANCE ..... 4
3. ROLES AND RESPONSIBILITIES ..... 5
4. STANDARD ..... 6
4.1 STANDARD OVERVIEW ..... 6
4.2 STANDARD REQUIREMENTS ..... 6
4.2.1 GENERAL AUTHENTICATION REQUIREMENTS ..... 7
4.2.2 "SOMETHING-YOU-KNOW" REQUIREMENTS ..... 9
4.2.4 "SOMETHING-YOU-HAVE" REQUIREMENTS ..... 11
4.2.10 "SOMETHING YOU ARE" REQUIREMENTS ..... 12
4.2.5 PRIVILEGED ACCOUNT REQUIREMENTS ..... 13
4.2.6 SINGLE SIGN ON AUTHENTICATION REQUIREMENTS ..... 14
4.2.7 Customer-Facing (User, Host to Host and IVR) ..... 15
5 REPORTING STRUCTURE AND ESCALATION ..... 17
6 EXCEPTIONS ..... 17
7 DOCUMENT HISTORY AND VERSION CONTROL ..... 18
7.1 OWNERSHIP AND AUTHORSHIP ..... 18
7.2 SIGN OFF ..... 19
7.3 SUBSIDIARY SIGN OFF ..... 19
8 APPENDIX ..... 20
8.1 APPENDIX A – KEY CONTACTS ..... 20
8.2 APPENDIX B – REGULATORY OBLIGATIONS ADDRESSED BY THIS STANDARD ..... 20
8.3 APPENDIX C – GLOSSARY ..... 21
8.4 APPENDIX D – RELATED POLICIES AND PROCESS AND ADMINISTRATIVE DOCUMENTS ..... 23

# 1. INTRODUCTION

## 1.1 Purpose of this Document

The Authentication and Authorization Standard (this "Standard") establishes the minimum mandatory requirements for securely verifying user identities and enforcing appropriate access to Combined US Operations of Banco Santander, S.A. ("CUSO") information systems and data. It applies to all CUSO subsidiaries, workforce members, applications, platforms, and technology environments that require authentication or authorization controls, including customer-facing, internal, cloud, and third-party hosted solutions.

This Standard outlines governance and control expectations for authentication factors, credential management, privileged access, single sign-on, and access enforcement commensurate with risk and data sensitivity. The objective of this Standard is to reduce unauthorized access risk, protect sensitive information, support regulatory compliance, and ensure consistent, auditable identity and access control practices across the enterprise.

## 1.2 Scope and Perimeter

This Standard applies to CUSO, including the business units operating through Santander Holdings USA, Inc. ("SHUSA") and its subsidiaries (individually, "Subsidiary," collectively, "Subsidiaries," and together with SHUSA, "Santander US") and the Banco Santander, S.A. New York Branch ("BSNY") first line of defense functional areas within the Technology division. Additional requirements that are specific to an individual Subsidiary can be found in the exceptions section of this Standard. Operating policies and/or standards developed by Subsidiaries must comply with the requirements set forth in this Standard.

This Standard applies to electronic information assets (e.g., information systems, applications, systems, platforms, and computer operations).

## 1.3 Document Ownership, Approval and Maintenance

This Standard is categorized as a CUSO Technology (First Line of Defense) document that is updated and maintained by the CUSO Technology function. This Standard is owned by the Santander US Chief Information Security Officer ("CISO") and approved by the Santander US Head of Technology and Operations ("T&O"). This Standard is reviewed and endorsed by Subsidiary standard owners.

This Standard is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review.

# 2. GOVERNANCE AND ACCOUNTABILITY

## 2.1 Standard Governance

The Santander US CISO will:

- Own and author, review, oversee implementation of, and monitor compliance with this Standard.

The Subsidiary standard owners will:

- Review and endorse this Standard.

The CUSO Technology and Operations Executive Working Group ("T&O EWG") will:

- Review and recommend approval of this Standard to the Santander US Head of T&O.

The Santander US Head of T&O will:

- Approve this Standard.

## 3. ROLES AND RESPONSIBILITIES

CUSO utilizes a three lines of defense ("LoD") model for risk management, with separately defined and segregated responsibilities consistent with applicable regulations and guidance.

### First Line of Defense – Risk Management

First line of defense ("1LoD") units have accountability for the primary management of the risks that emanate from their activities. 1LoD units own, identify, measure, control, monitor, and report all risks that are originated through activities such as business origination, the development, marketing or distribution of products, client maintenance, or operational or technological processes supporting customer activity.

**Technology** is the 1LoD unit accountable for owning, authoring, reviewing, overseeing implementation of, and monitoring compliance with this Standard. Accountabilities of individual functional areas within Technology are defined in Section 4.

### Second Line of Defense – Risk Control

The **Risk** function is a second line of defense ("2LoD") unit that outlines risk management frameworks and policies, independently monitors risk exposures, implements comprehensive and appropriate risk controls, and reviews and challenges 1LoD units on their activities to ensure that risk is managed in line with the agreed frameworks and Risk Appetite levels. The Risk function is organized by risk type (e.g., Enterprise Risk Management ("ERM"), Compliance, Credit, Market, Liquidity, Operational, and Model Risk) and other specialized functions (Risk Analytics) at the CUSO and Subsidiary levels. The ERM function administers Risk Governance & Reporting, Material Risk Program, Strategic Risk, Climate Risk, New Product & Business Activities, and Risk Appetite programs. The Second LoD takes primary responsibility for designing and documenting comprehensive enterprise-wide risk management framework that meets regulatory guidelines and is commensurate with the size, complexity, and risk profile of the covered subsidiaries and will be held accountable by the Chief Executive Officer ("CEO") and the Board.

### Third Line of Defense – Risk Assurance

**Internal Audit** is independent of any other function or unit in CUSO and provides independent assurance to the Board and senior management by assessing the quality and effectiveness of the processes and systems of internal control, risk management and risk governance, compliance with applicable regulations, and the reliability and integrity of financial and operational information.

# 4. STANDARD

## 4.1 Standard Overview

This Standard defines the minimum mandatory requirements for the behavior and capabilities to positively identify a user (i.e., authentication) and grant allowed access to information assets (i.e., authorization).

## 4.2 Standard Requirements

The following requirements and objectives should be considered for activities that support Authentication and Authorization Management at CUSO (for the purpose of this Standard, there are three factors as described below):

**Something-you-have**

Something-you-have authentication proves possession of a physical or logical object. Something-you-have authentication must only be used when the owner of the object is an individual who has control over the object and responsibility for the object.

- **Physical one-time password token:** A physical token produces a one-time password and provides something-you-have authentication. The one-time password cannot be guessed without physical possession of the token. The one-time password must be derived using a pseudo-random number generator from a seed locked within the physical token. The one-time password may be a truncated value computed from the pseudo-randomly generated sequence, provided the one-time token value is not less than six digits. The seed of the pseudo-random number generator must be secured. The one-time password produced by the token may be event-based or time-based.
- **Logical one-time password token:** A logical token produces a one-time password and provides something-you-have authentication. The one-time password cannot be guessed without access to the logical token. The logical token may be an application residing on a mobile device or desktop. The one-time password must be derived using a pseudo-random number generator from a seed locked within the logical token application. The one-time password may be a truncated value computed from the pseudo-randomly generated sequence provided the one-time token value is not less than six digits. The seed of the pseudo-random number generator must be secured within the software application. The one-time password produced by the token may be event-based or time-based.
- **Digital signature software or hardware:** Digital signature software or hardware computes a digital signature over data provided as input and provides something-you-have authentication. Use of digital signature software or hardware requires replay detection and rejects digital signatures computed over replayed data.
- **Machine fingerprint:** A machine fingerprint collects attributes from a device and forms a fingerprint by analyzing the attributes. A machine fingerprint may be used to detect when a device visits and later returns.
- **Short Message Service (“SMS”) or phone number:** Proof of control of a mobile phone must provide something-you-have for one-time-passwords distributed through text messages or voice. The user proves something-you-have by receiving the text message and copying it back to the application to which the individual requests authentication.

**Something-you-know**

- Something-you-know is considered the knowledge factor and consists of information that a user possesses. This may include usernames combined with a password or Personal Identification Number (“PIN”).

**Something-you-are**

- Something-you-are is considered the inherence factor and is typically based on a form of biometric identification based upon an individual's physical characteristics, such as a fingerprint. Behavioral biometrics (e.g., keyboard typing speed) must not be considered a form of authentication but may be used in a layered risk decision.

### 4.2.1 General Authentication Requirements

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.1.1 | s-CISO | **Authentication Method**<br>The authentication method must be implemented based on CUSO employee and contractor access as outlined below:<br>• Single-Factor Authentication refers to "something -you-know" as the authentication method.<br>• Two-Factor Authentication refers to two out of "something-you-know", "something-you-have" and "something-you-are" as the authentication methods.<br>• Three-Factor Authentication refers to a combination of "something-you-know", something-you-have" and "something-you-are".<br>All CUSO network and CUSO application authentication must be Two-Factor or greater.<br>For customer or client facing host-to-host applications and for third-party applications with internal or confidential data, One-Factor plus IP restrictions must be considered as an acceptable authentication method.<br>Phishing resistant MFA must be required for high-risk access. |
| SUS.AAS.4.2.1.2 | s-CISO | Somewhere-you-are technology (e.g., geolocation) must not be considered an authentication technology but may be used in a layered risk decision. |
| SUS.AAS.4.2.1.3 | s-CISO | **Unique Identifier**<br>Person accounts must be uniquely tied to an individual and must not be shared. All non-person accounts must have an identified owner. |
| SUS.AAS.4.2.1.4 | s-CISO | **Session Timeout**<br>If a user workstation or mobile device has been idle for more than 10 minutes, the user must be required to re-authenticate to re-activate the session.<br>A user workstation Virtual Private Network ("VPN") session's duration must not exceed six days and 20 hours. |

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.1.5 | s-CISO | **Logging**<br>All authentication attempts, both successful and unsuccessful, must be logged in accordance with the *CUSO Logging and Monitoring Standard* and with the *CUSO Public Cloud Standard*. |
| SUS.AAS.4.2.1.7 | s-CISO | **Windows Hello:** Windows Hello is considered an approved form of Two-Factor authentication provided that facial or fingerprint recognition is required. |
| SUS.AAS.4.2.1.10 | s-CISO | The Windows Hello for Business PINs length and complexity must:<br>• Be eight (8) characters in length<br>• Include at least one (1) uppercase letter<br>• Include at least one (1) lowercase letter<br>• Include at least one (1) number<br>• May include special characters such as !, ?, @. #, $, etc. |
| SUS.AAS.4.2.1.9 | Santander US CISO | A systematic method of blocking commonly used passwords must be in place for Active Directory accounts. |
| SUS.AAS.4.2.1.11 | s-CISO | APIs must employ one of the following approved methods of authentication (where applicable):<br>1. Mutually Authenticated Transport Layer Security (“mTLS”) or<br>2. OpenID Connect (“OIDC”) or OAuth2 token-based authentication, communicated exclusively over TLS 1.2 or higher; or<br>3. A dedicated IPSec tunnel providing secure, encrypted channel establishment. |
| SUS.AAS.4.2.1.12 | s-CISO | Multi Factor Authentication (“MFA”) method registration must only be permitted from trusted locations, trusted devices, or with a Temporary Access Pass issued by an administrator.<br>Users without registered MFA methods must be prompted to register during their next sign-in from a compliant context. The MFA registration policy must be enforced through a conditional access policy in the identity provider (Entra ID). |
| SUS.AAS.4.2.1.13 | s-CISO | When sign-in risk is detected at high level, authentication will be blocked. Sign-in risk signals must include anonymous IP addresses, impossible travel, unfamiliar sign-in properties, and malware-linked IP addresses. Sign-in risk evaluation must be integrated into conditional access policy decisions in the identity provider (Entra ID). |

### 4.2.2 "Something-You-Know" Requirements

Single Factor Authentication refers to "something-you-know" as the authentication method.

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.2.1 | s-CISO | **Passwords in Storage**<br>Passwords in storage must be stored in an approved container and either:<br>• Hashed, salted, and protected with a key or<br>• Hashed and encrypted.<br>In Santander US public cloud landing zone, all password encryption/decryption must be performed with a vaulted key. |
| SUS.AAS.4.2.2.11 | s-CISO | Password hash synchronization from on-premises Active Directory to the cloud identity provider (Entra ID) must be implemented to enable seamless hybrid identity authentication.<br>Password hashes synchronized to the cloud must maintain the same hashing, salting, and encryption protections required for passwords in storage. |
| SUS.AAS.4.2.2.2 | s-CISO | **Passwords in Transit**<br>Passwords must be encrypted in transit. |
| SUS.AAS.4.2.8.3 | s-CISO | **Password Communication**<br>Passwords must be communicated to the owner of that password (or in the case of new users to a custodian, such as the owner's manager) by:<br>• ServiceNow Password field, which can be read only by the Administrator who entered the password and the requestor who requested the password.<br>• Santander internal email following appropriate data classification standards.<br>• Santander Microsoft ("MS") Teams in one-to-one chat. |
| SUS.AAS.4.2.9.1 | s-CISO | **Forgotten Password**<br>A means of replacing a lost/forgotten password must be provided and be auditable. |
| SUS.AAS.4.2.2.9 | s-CISO | **Person-Accounts**<br>An account initial password change must be enforced upon first login. |

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.2.3 | s-CISO | **Person Accounts: 1FA - Password Expiration**<br>Passwords assigned to individuals must automatically expire every 45 days.<br>Note: External customers are excluded from this requirement. |
| SUS.AAS.4.2.2.10 | s-CISO | All users must access Santander resources with MFA using trusted device (Entra ID and corporate identities). |
| SUS.AAS.4.2.2.4 | s-CISO | **Person Accounts**<br>Passwords must consist of a minimum of eight (8) characters. |
| SUS.AAS.4.2.2.5 | s-CISO | **Person Accounts**<br>Passwords must not match any of the twelve (12) previously used. |
| SUS.AAS.4.2.2.8 | s-CISO | **Person Accounts**<br>Password age must be greater than or equal to one (1) day. |
| SUS.AAS.4.2.2.6 | s-CISO | **Person Accounts**<br>Passwords must have three of the following four (4) characteristics: lowercase letters, uppercase letters, numbers, or symbols. |
| SUS.AAS.4.2.2.7 | s-CISO | **Person Accounts**<br>Person Accounts must be locked out after no more than five (5) consecutive failed login attempts and remain locked for at least 30 minutes, or until an administrator unlocks the account. |
| SUS.AAS.4.2.8.1 | s-CISO | **Person-Accounts**<br>Temporary Person-Account credentials and administrator or help desk assigned credentials must be controlled through a password random generator process which securely generates them. |

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.3.6 | s-CISO | **Service Account**<br>Non-Cloud Service accounts must employ one of the following methods of authentication:<br>a. Mutually authenticated TLS (“mTLS”) or<br>b. Open ID Connect (“OIDC”) token communicated over TLS or<br>An account password or API key that is regularly rotated and custodied through the approved Privileged Access Management System (“PAMS”), OR that the password meets the following requirements:<br>• Password age must be greater than or equal to one (1) day.<br>• Process must exist for generating new password that creates a password of 18 characters or more.<br>• Passwords must have at least three (3) alpha characters and one (1) numeric digit and must include both upper and lowercase characters.<br>• Passwords must not expire. |
| SUS.AAS.4.2.3.5 | s-CISO | **Non-person-accounts**<br>By default, interactive logon to operating system non-person-accounts must be disabled, otherwise must be onboarded through PAMS and s-CISO approval required. |
| SUS.AAS.4.2.3.8 | s-CISO | **Non-person-accounts**<br>Non-person-accounts must have a defined lifecycle process. |
| SUS.AAS.4.2.3.2 | s-CISO | **Non-persons account - Passwords in Transit**<br>Passwords for Service accounts, API passwords or keys must be encrypted while in transit. |
| SUS.AAS.4.2.3.9 | s-CISO | **Non-person-accounts**<br>Non-person-accounts in the Santander US public cloud landing zone must use cryptographic authentication with vaulted keys. |

### 4.2.4 “Something-You-Have” Requirements

Two-Factor Authentication refers to two out of “something-you-know”, “something-you-have” and “something-you-are” as the authentication methods.

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.4.3 | s-CISO | **Digital Signatures**<br>For Two-Factor Authentication, all requirements relating to One-Factor Authentication are required, plus authentication using a digital signature if a password is required to unlock the private key. |
| SUS.AAS.4.2.4.2 | s-CISO | **Machine Fingerprinting**<br>A machine fingerprint must be combined with an approved risk-analysis solution in order to be considered a valid form of two-factor authentication.<br>The risk-analysis solution must be approved by the s-CISO and must evaluate data received within the login session provided by the device or transaction within its real-time constraints. |

### 4.2.10 "Something You Are" Requirements

Two Factor Authentication refers to two out of "something-you-know", "something-you-have" and "something-you-are" as the authentication methods.

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.4.5 | s-CISO | **Digital Signatures**<br>The data communicated from the individual's device to Santander proving a biometric authentication must be digitally signed using a technology suitable for additionally proving something-you-have. |
| SUS.AAS.4.2.1.6 | s-CISO | **FIDO**<br>Biometric authentication must comply with the FIDO standard, where applicable. |
| SUS.AAS.4.2.1.8 | s-CISO | **Server Access**<br>Direct access to servers, including but not limited to SSH and RDP connections, must only be used through an approved session management solution, such as CyberArk. |

### 4.2.5 Privileged Account Requirements

There is a subset of system accounts (database and server privileges) that are very high risk due to their potential impact across the enterprise.

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.5.1 | s-CISO | **Privilege Access - 2FA**<br>Two-factor authentication is required for privileged access by individual IDs. |
| SUS.AAS.4.2.5.6 | The Head of Privilege Access Management (“PAM”) | **Definition of Privilege**<br>The criteria used to determine what accounts are considered privileged must be defined and documented. |
| SUS.AAS.4.2.5.2 | s-CISO | **Privileged Person Accounts**<br>Privileged person accounts must only be used through an approved session management solution.<br>Session management for Privileged person accounts must include:<br>• Logging and monitoring integrated into an approved Security Information and Event Management (“SIEM”) solution.<br>• Password vaulting and key rotation. |
| SUS.AAS.4.2.5.3 | s-CISO | **Privileged Person Accounts**<br>Infrastructure privileged accounts must be assigned a different account and password than that used for their normal use, and that privileged account must be uniquely assigned to the individual and not shared.<br>A different account is not required if Privileged Session Management or Privileged Control Access (“PCA”) is for Cloud usage. |
| SUS.AAS.4.2.5.7 | s-CISO | **Privileged non-person-accounts**<br>Non-person operating systems and database accounts that support Sarbanes Oxley (“SOX”) or Gramm-Leach-Bliley Act (“GLBA”) applications or are in a production environment and have interactive login must have their passwords or keys vaulted in an approved vaulting solution. Password or key rotation is not required. |
| SUS.AAS.4.2.5.8 | s-CISO | SSH key authentication is not permitted for third-party connections within the PAMS. |

### 4.2.6 Single Sign on Authentication Requirements

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.6.4 | Head of Identity and Access Management ("IAM") | **Approved Single Sign-On ("SSO") Methods**<br>A list of approved SSO methods must be maintained (e.g., Ping, Active Directory Federation Services ("ADFS"), Azure AD). |
| SUS.AAS.4.2.6.8 | s-CISO | CUSO must implement a Global Identity Provider ("GIP") as the single authoritative source for identity, authentication, and access control.<br>The GIP must support hybrid identity, ensuring identities, credentials, and authentication policies are consistently enforced across both on-premises and cloud environments.<br>Entra ID must be designated as the approved GIP for CUSO. |
| SUS.AAS.4.2.6.5 | s-CISO | **SSO**<br>Authentication to SOX, GLBA applications must be via an approved SSO method. |
| SUS.AAS.4.2.6.6 | s-CISO | **SSO**<br>Authentication to applications with a data classification of Restricted-Confidential or Secret must be via an approved SSO method. |
| SUS.AAS.4.2.6.3 | s-CISO | **Third Party Hosted Applications**<br>Authentication to applications hosted at a third party must be via one of the following two methods:<br>• An approved SSO method.<br>OR<br>• All the following:<br>  ○ An application which is not at the Restricted Confidential or Secret data classification AND<br>  ○ An ARB approved authentication process which includes a method to de-provision in the case of termination or transfer AND<br>  ○ Internet Protocol ("IP") address restrictions to a CUSO IP source address or dedicated connections (VPN, Multiprotocol Label Switching ("MPLS"), Internet Protocol Security ("IPsec")) (thereby requiring all users of the service to either be on-site at a CUSO physical location or logged into the network via remote access) |

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.6.7 | s-CISO | **Software as a Service ("SaaS")**<br>Authentication to SaaS applications must be via the following three methods:<br>• Corporate Authentication via Entra ID and<br>• MFA with Device Control and<br>• IP Whitelisting to restrict access from approved source locations |

### 4.2.7 Customer-Facing (User, Host to Host and IVR)

Where applicable, relevant authentication requirements in this standard apply to customer-facing platforms. The determination for customer authentication requirements, including any additional requirements or deviations from this standard, must be reviewed as part of the security solutioning process for the deployment of new platforms.

Where deemed appropriate by the CISO, a dedicated technical standard or reference architecture may be required to specifically address the needs of a particular customer facing solution or product.

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.7.2 | s-CISO | **Customer-Facing – Host-to-Host**<br>Transmissions from external customers (outside of Santander control) must require two-factor authentication, this may consist of:<br>1. Password and IP Restrictions<br>2. Password and Digital Signature<br>The customer must be contractually obligated to secure any private key generated by the customer and confirm all access to the private key is authorized. |
| SUS.AAS.4.2.7.3 | s-CISO | **Customer-Facing – Interactive Voice Response ("IVR")**<br>Requires two-factor authentication. |
| SUS.AAS.4.2.7.4 | s-CISO | **Customer-Facing – IVR something-you-know**<br>Something-you-know requires a four (4) digit or alphanumeric PIN known only by the user; and another six (6) or more digit or alphanumeric value that is not publicly available. Examples of non-publicly available numbers are account numbers, credit card numbers, and ATM account numbers. |

| Requirement ID | Accountable Role / Function | Requirement |
|---|---|---|
| SUS.AAS.4.2.7.5 | s-CISO | **Customer-Facing – IVR something-you-have**<br>Something-you-have requires validation of an authorized voice device. Authorized methods of authenticating a voice device must include spoof detection, call-back, anti-spoof technology, and cryptographic authentication. Something-you-have technology must not be used for authenticating a device unless approved by the Subsidiary CISO. |
| SUS.AAS.4.2.7.6 | Santander US CISO | **Customer-Facing – IVR something-you-are**<br>Something-you-are (IVR biometrics) technology must be approved by the Santander US CISO. |
| SUS.AAS.4.2.7.7 | s-CISO | **Customer-Facing – IVR Mobile Device Authentication**<br>Two-factor authentication using something-you-have and something-you-are must be permitted when opening a connection using the app installed on the mobile device if the app uses approved cryptographic authentication with keys bound to the device. When using crypto-enabled something-you-have combined with something-you-are, the something-you-are technology may leverage the technology offered through the device itself provided that layered controls confirm enforcement. |

## 5 REPORTING STRUCTURE AND ESCALATION

As part of an overarching risk assessment and reporting program, CUSO must conduct regular self-assessments to measure design adequacy and operating effectiveness of controls specified in this Standard. The results must be incorporated into risk reporting provided to the CUSO 2LoD functions, and to the Board, if applicable, in accordance with the 2LoD function's governance requirements.

## 6 EXCEPTIONS

Standard exceptions are expected to be infrequent but may be granted to address specific business needs. Subsidiary-specific exceptions require review and approval from both the s-CISO and the Santander US CISO. All approved Subsidiary-specific exemptions are listed in the table below.

Any additional material exceptions not explicitly defined in this section must include documented rationale, an assessment of associated risks (where applicable), and any other relevant details. These exceptions must be reviewed and approved during the Security Exceptions Function ("SEF") meeting.

| Subsidiary: | Exceptions/Additions: |
|---|---|
| **SBNA:** | • No exceptions |
| **BSNY:** | • Removed reference to ATM from requirement 4.2.7.4 as BSNY does not have ATMs. |
| **SanCap:** | • Removed reference to ATM from requirement 4.2.7.4 as SanCap does not have ATMs. |
| **SC:** | • Removed reference to ATM from requirement 4.2.7.4 as SC has no ATMs. |
| **BSI:** | • Removed reference to ATM from requirement 4.2.7.4 as BSI has no ATMs.<br>• SUS.AAS.4.2.7.3 - SUS.AAS.4.2.7.7 The Interactive Voice Response ("IVR") portion of this requirement does not apply to BSI as BSI does not have an IVR system and no plans to implement. |

# 7 DOCUMENT HISTORY AND VERSION CONTROL

## 7.1 Ownership and Authorship

| Version | Author | Owner | Change |
|---|---|---|---|
| 1.0 | Santander US Information Risk Management | Santander US CIRO | Initial Version |
| 2.0 | Santander US Technology | Santander US CISO | Annual Update |
| 3.0 | Santander US Technology | Santander US CISO | Refresh based on updated IRM Taxonomy |
| 4.0 | Santander US Technology | Santander US CISO | Annual Update |
| 5.0 | Santander US Technology | Santander US CISO | Annual Update |
| 6.0 | Santander US Technology | Santander US CISO | Aligned with Group and NIST password requirements |
| 7.0 | Santander US Technology | Santander US CISO | 2021 Annual Update |
| 8.0 | Santander US Technology | Santander US CISO | 2022 Annual Update |
| 9.0 | Santander US Technology | Santander US CISO | 2023 Off Cycle Update |
| 10.0 | Santander US Technology | Santander US CISO | 2023 Annual Update |
| 11.0 | Santander US Technology | Santander US CISO | 2024 Off Cycle update to align password length and added requirement for nominal users accessing servers via CyberArk. |
| 12.0 | Santander US Technology | Santander US CISO | 2024 Annual Update |
| 13.0 | Santander US Technology | Santander US CISO | 2025 Annual Refresh |

## 7.2 Sign Off

| Approver | Action | Date |
|---|---|---|
| Santander US Head of T&O | Approve | 07/28/2026 |

## 7.3 Subsidiary Sign Off

| Approving Body | Governance Committee Approval or Endorsement | Final Approval Date |
|---|---|---|
| Santander US CISO | Endorsement | 07/22/2026 |
| SBNA CISO | Endorsement | 05/20/2026 |
| Santander US Auto Chief Information Officer (“CIO”) | Endorsement | 07/21/2026 |
| BSI CIO | Endorsement | 07/23/2026 |
| Santander US Corporate and Investment Banking (“CIB”) CIO | Endorsement | 07/28/2026 |

# 8 APPENDIX

## 8.1 Appendix A – Key Contacts

| Title | Role | Contact Information |
|---|---|---|
| Santander US Head of T&O | CUSO Technology | Patryk Nowakowski (patryk.nowakowski@santander.us) |
| Santander US CISO | CUSO Information Security | Alberto Hernandez (Alberto.Hernandez@santander.us) |
| Sr. Director, Information Security | CUSO Information Security | Robert Burden (robert.burden@santander.us) |
| SBNA CISO | CUSO Information Security | Andre Salgado (andre.salgado@santander.us) |
| Santander US Auto CIO | CUSO Technology | Bobby Mehra (Bobby.mehra@santander.us) |
| Sr. Director, Information Security | CUSO Information Security | Rebecca Smith (rebecca.smith@santander.us) |
| BSI CIO | Banco Santander International Technology | Jose Oliveros (joliveros@bpi-gruposantander.com) |
| Sr. Director, Information Security | Banco Santander International Technology | Dayam Borges (dborges@bpi-gruposantander.com) |
| Santander US CIB CIO | CUSO Capital Markets, LLC/Banco Santander New York Technology | Xavier Jean Courtois (xavier.courtois@santander.us) |
| CIB Chief Information Security Officer | CUSO Capital Markets, LLC /Banco Santander New York Technology | Frank Hsieh (frank.hsieh@santander.us) |

## 8.2 Appendix B – Regulatory Obligations Addressed by this Standard

The following are the primary regulations addressed by CUSO Technology Standards:

- GLBA 501(b) - Interagency Guidelines Establishing Standards for Safeguarding Customer Information
- GLBA 501(b) - Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice

In addition, CUSO considered the following supervisory sources in developing Standards and in its ongoing assessment and oversight of risk:

- Federal Financial institutions Examination Council (“FFIEC”) IT Handbook, including:
    - Information Security Booklet

- Development and Acquisition Booklet
- Architecture, Infrastructure, and Operations Booklet
- Management Booklet
- Outsourcing Technology Booklet
- Supervision of Technology Service Providers Booklet
- Business Continuity Management Booklet

- Office of the Comptroller of the Currency (“OCC”) Model Risk Management booklet of the Comptroller's Handbook
- US Securities and Exchange Commission 2017-02 Guidance Update (Robo Advisers)
- National Institute of Standards and Technology (“NIST”) Artificial Intelligence Risk Management Framework (AI RMF 1.0)
- International Standards Organization (“ISO”) ISO/IEC 38507:2022 Information Technology — Governance of IT — Governance implications of the use of Artificial Intelligence by organizations
- The National Cyber Security Centre (“NCSC”) Guidelines
- Personal Data Protection Commission Singapore (“PDPC”) Model
- Monetary Authority of Singapore

## 8.3 Appendix C – Glossary

| Term | Definition |
|---|---|
| **Application Access Administrator** | The individual responsible for provisioning and de-provisioning access to an application in response to appropriately approved requests and work items raised as consequence of application attestation and certification activities and other controls implemented to confirm that application access is appropriate. |
| **Application Administrator** | The individual responsible for the operation of the application. Operational tasks include but are not limited to the execution and evidence retention of security, performance, availability, operational compliance, incident, change, release, and configuration tasks. |
| **Application Owner** | The individual accountable for the life cycle and operation of an application in support of a business process. |
| **Conditional Access Policy** | Conditional Access Policy framework requires CUSO to implement if-then policy rules within the identity provider (Entra ID). These rules evaluate signals including user identity, device compliance, network location, application sensitivity, and real-time risk levels to make dynamic access decisions (grant access, require MFA, or block).<br>Conditional access policies must be documented, reviewed at least annually, and aligned with the Zero Trust principle of "never trust, always verify." |
| **Entra ID** | Entra ID is a cloud-based identity and access management (“IAM”) service that provides authentication and authorization for various Microsoft services and third-party applications. |

| Term | Definition |
|---|---|
| **First Line Information Security** | The function responsible for execution of the enterprise Information Security Management program and for the execution of Information Security operational processes. |
| **Information Owner** | The individual accountable for the data involved in one or more Applications and/or IT Systems. |
| **Manager / Supervisor** | The person to whom a workforce member directly reports. |
| **Login Session** | User based session defined by the period of activity between a user logging in and logging out of a (multi-user) system. |
| **Privileged Access** | Asset administration or configuration activity executed through Privileged accounts. |
| **Privileged Account** | Any user with permission to create and modify user profiles, or have permission to modify security programs, configurations or systems settings. |
| **PAMS** | Privileged Access Management System (e.g. CyberArk) |
| **Privileged Access Management Team** | The team within First Line Information Security that is responsible for managing and maintaining the operating process of the Privileged Access Management program. |
| **s-CISO** | The executive accountable for managing the Information Security function at one of CUSO subsidiaries. |
| **SaaS** | The capability provided to CUSO is to use the provider's applications running on a Cloud infrastructure. The applications are accessible from various client devices through either a thin client interface, including a web browser (e.g., web-based email), or a program interface. The consumer does not manage or control the underlying Cloud infrastructure, including network, servers, operating systems, storage, or even individual application capabilities, apart from limited user specific application configuration settings. |
| **Santander US CISO** | The executive accountable for managing the Information Security function at CUSO. |
| **Service Account** | Service accounts are a special type of non-human account used to execute applications and run automated services.<br>They can be local or domain accounts. Service accounts should be used by system services. |
| **Sign-in Risk** | Sign-in risk is defined as the assessment of the likelihood that an authentication request is not authorized by the identity owner. Risk signals |

| Term | Definition |
|---|---|
| | include, but not be limited to: unfamiliar IP addresses, atypical travel patterns (impossible travel), anonymous/VPN-sourced connections, and unrecognized or non-compliant devices.<br>Sign-in risk levels (low, medium, high) are integrated into conditional access policies to trigger step-up authentication or block access as appropriate. |
| **Trusted Location** | Trusted Location is defined as a named set of IP address ranges representing CUSO corporate offices, VPN egress points, and other verified network locations.<br>Trusted locations are maintained as a centralized reference in the identity provider (Entra ID) and used as a signal in conditional access policies to adjust authentication requirements based on user location. |
| **Workforce Members** | Employees, contractors, vendors, interns, volunteers, trainees, and other persons whose conduct, in the performance of work for Santander, is under the policies, standards, etc. of Santander, whether their employment is directly with Santander. |

## 8.4 Appendix D – Related Policies and Process and Administrative Documents

| Document Type | Subsidiary / Department | Owner | Title |
|---|---|---|---|
| Policy | CUSO Operational Risk Management | Santander US Chief Operational Risk Officer | CUSO Information Risk Management Enterprise Policy |
| Policy | CUSO Technology | Santander US CISO | CUSO Information Security Operating Policy |
| Standard | CUSO Technology | Santander US CISO | CUSO Identity and Access Management Standard |
| Standard | CUSO Technology | Santander US CISO | CUSO Security Logging and Monitoring Standard |
| Standard | CUSO Technology | Santander US CISO | CUSO Encryption and Data Masking Standard |
| Standard | CUSO Technology | Santander US T&O Chief Operating Officer (“COO”) | CUSO Public Cloud Standard |